

Warsaw, March 12, 2024

Decision

DKN.5131.59.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended), Article 7(1) and (2), as well as Articles 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), and also Article 57(1)(a) and (h), Article 58(2)(e) and (i), Article 83(1), (2), and (3), Article 83(4)(a) in connection with Article 33(1) and Article 34(1), (2), and (4) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative procedure regarding the violation of personal data protection regulations by Santander Bank Polska S.A. based in Warsaw (Al. Jana Pawła II 17, 00-854 Warsaw), the President of the Personal Data Protection Office, 1) stating that Santander Bank Polska S.A. based in Warsaw (Al. Jana Pawła II 17, 00-854 Warsaw) violated the provisions: a) Article 33(1) of Regulation 2016/679, consisting of failing to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, no later than 72 hours after becoming aware of the breach, b) Article 34(1) of Regulation 2016/679, consisting of failing to inform without undue delay the individuals whose data are affected by the personal data breach, imposes on Santander Bank Polska S.A. based in Warsaw (Al. Jana Pawła II 17, 00-854 Warsaw) an administrative fine in the amount of 1,440,549 PLN (in words: one million four hundred forty thousand five hundred forty-nine zlotys), 2) orders Santander Bank Polska S.A. based in Warsaw (Al. Jana Pawła II 17, 00-854 Warsaw) to notify - within 3 days from the date of delivery of this decision - the individuals whose data protection has been breached as a result of the event recorded in the Personal Data Breach Register of Santander Bank Polska S.A. under number (...), about the breach of their personal data protection in order to provide these individuals with the information required under Article 34(2) of Regulation 2016/679, namely: a) a description of the nature of the personal data breach; b) the name and contact details of the data protection officer or the designation of another contact point from which more information can be obtained; c) a description of the possible consequences of the personal data breach; d) a description of the measures taken or proposed by the controller to address the breach - including measures to mitigate its potential negative effects.

Justification

On August 23, 2022, the President of the Personal Data Protection Office, hereinafter also referred to as the "President of UODO" or "supervisory authority", received information from an article published on the website (...) at the address (...), regarding a breach of personal data protection of customers of Santander Bank Polska S.A. based in Warsaw, hereinafter referred to as the "Bank" or "Controller", consisting of the public disclosure of banking documents found in a package abandoned in the K. housing estate, after it had been previously stolen during transport by a courier company. The article itself was published on (...) November 2018, while the incident occurred on (...) November 2018. The posted entry indicates that "(...)". The incident was also reported two days earlier by the service (...).

In connection with the above, by letter dated August 25, 2022, the President of UODO, based on Article 58(1)(a) and (e) of Regulation 2016/679, requested the Bank to clarify whether, in connection with the incident, the Bank reported, in accordance with Article 33 of Regulation 2016/679, the personal data breach to the President of UODO in the above regard, and if so, when and how it did so, and whether the Bank fulfilled the obligation to notify the individuals whose data are affected about the breach of their personal data, in accordance with Article 34(1) and (2) of Regulation 2016/679. The President of UODO also requested to indicate: when and how the Bank determined that the specified documents had been made public, the number of individuals affected by the personal data breach in question, the period from which the disclosed documents originate, and an explanation of what actions were taken to minimize the risk of such incidents occurring again in the future.

By letter dated September 5, 2022, the Bank requested the President of UODO to extend the deadline for providing a response to September 16, 2022, arguing that it was necessary to “thoroughly establish (with many individuals representing various units in the bank), namely: to investigate the circumstances of the incident after its disclosure; the grounds for the assessment made by the bank regarding the incident; the conclusions and actions that the bank took in connection with the occurrence of this incident, in order to comprehensively respond to the questions of the President of the Personal Data Protection Office.” From the response provided by the Bank in the letter dated September 16, 2022, it follows that the Bank determined that to finding of the documents indicated in the letter from the supervisory authority in the block in K. occurred on (...) November 2018. This was carried out by the entity (...), conducting monitoring of information appearing on the Internet. On the portal (...) it found a post regarding the discovery of the Bank's documents in the block in K. Two days later, the event was also reported by the portal (...). The data protection breach concerned a maximum of 158 individuals (this number was determined based on the data contained in the documentation sent, indicating the identification numbers of the clients whose documents were found). The publicized documents originated from the period from (...) November 2018 to (...) November 2018 (the date of dispatch of the shipment in the (...) Branch of the Bank in K.). The data protection breach was not reported to the President of UODO. The following circumstances influenced this decision: the shipment was found by one identified person shortly after its loss by the courier; it was verified that no documents were missing; the person who found the documents took them directly to the police station; this person admitted that they did not copy the documents. Consequently, the individuals whose data was involved were not informed about the data protection breach. The Bank also described the actions taken to minimize the risk of recurrence of such events in the future, as a result of which a working group was established, tasked with analyzing the event and developing mechanisms to prevent similar situations in the future. “(...) As a result of the work of this group: 1) a "Standard" for the process of sending paper documentation was developed, including: a. preparation of the shipment / method of packaging — use of (...). The label (...) has the following content “(...)” b. control of the "Standard" at three levels: i) control on the courier's side — (...), ii) control carried out by (...), iii) control on the G. side - (...), c. response to events (detected irregularities). 2) an alert control of the correctness of sending shipments with G. documentation was conducted. As a result of this control, the following post-control actions were established: - an Instruction for sending shipments for the Bank's Branches was prepared, - emails were sent to each branch that incorrectly sent a shipment with information on how to correctly send a package with documentation to G., - engagement of direct control employees — during visits to branches, they instruct branch employees on how to correctly send shipments with documentation, 3) discussions were held with the courier regarding the communication process, including in particular: i) required times and methods of response to reported irregularities / identified events, ii) communication tools, iii) documentation of explanations / statements.” In connection with the explanations provided so far in the matter, by letter dated October 6, 2022, the President of UODO additionally requested the Administrator to: 1) specify the exact scope of personal data contained in the bank documentation covered by the data protection breach; 2) clarify whether, in relation to the disclosed personal data of clients, Santander Bank Polska S.A. is the sole data administrator; or if, in the event that personal data disclosed are also administered by other entities, whether the Bank notified them of this data protection breach. By letter dated October 20, 2022, the Bank requested an extension of the deadline for responding to the above letter until October 27, 2022. In the response dated October 27, 2022, the Administrator indicated that the documentation covered by the data protection breach contained the following categories of personal data: surnames and first names, dates of birth, bank account numbers, residential or temporary addresses, PESEL identification numbers, email addresses, usernames and/or passwords, data regarding earnings and/or owned assets, series and numbers of identity cards, phone numbers, information about banking products, loans, bank accounts, i.e., names of contracts, dates of their conclusion, details of these products, information about property insurance policies, i.e., including policy numbers, dates of issue, sums insured, insurance premiums, information regarding insured property. At the same time, the Bank indicated that the bank documentation covered by the data protection breach did not contain data referred to in Article 9 or Article 10 of Regulation

2016/679. Furthermore, the bank documentation covered by the data protection breach contained two insurance policies issued for the property insurance contracts of bank clients. In the scope of these insurance contracts, the data administrators are the insurance companies, which the Bank did not notify of the data protection breach. Due to the lack of notification of the data protection breach to the President of the Personal Data Protection Office and the lack of notification of the data protection breach to the individuals concerned, on December 8, 2022, the President of UODO initiated ex officio administrative proceedings against the Bank regarding the possibility of the Bank violating Article 33(1) and Article 34(1) and (2) of Regulation 2016/679. In initiating the administrative proceedings, the President of UODO called on the Bank to indicate, among other things, on what basis the administrator considered that the data protection breach of clients of Santander Bank Polska S.A. did not require notification to the supervisory authority and resulted in the lack of necessity to notify the individuals concerned about the breach. At the same time, the President of UODO requested the submission of the risk analysis conducted for this breach.

In response to the notification of the initiation of administrative proceedings in this matter, by letter dated December 19, 2022, the Bank provided additional explanations, indicating that the breach of personal data protection of the Bank's clients, which occurred as a result of the theft of a shipment containing the Bank's documentation during its transport by a courier company, and subsequently the abandonment of the opened shipment in a closed housing estate in K., was recorded in the Register of Personal Data Breaches of Santander Bank Polska S.A., under number (...). The risk assessment of the breach of rights and freedoms of the data subject was determined to be low, and this assessment was influenced by the following circumstances: the shipment was found by one identified person shortly after its loss by the courier; the Bank verified that no documents were missing; the person who found the documents took them directly to the police station; this person admitted that they did not copy the documents.

As a result of this assessment, the incident was not reported to the President of the Personal Data Protection Office. At the same time, the Bank also decided not to notify the individuals affected by this breach. After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

According to the definition contained in Article 4 point 12 of Regulation 2016/679, a "personal data breach" is a security breach leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed. Article 33 paragraph 1 and 3 of Regulation 2016/679 states that in the event of a personal data breach, the controller shall without undue delay – where feasible, no later than 72 hours after becoming aware of the breach – notify the supervisory authority competent under Article 55, unless it is unlikely that the breach will result in a risk to the rights or freedoms of natural persons. The notification submitted to the supervisory authority after the 72-hour period must include an explanation of the reasons for the delay. The notification referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects concerned, as well as the categories and approximate number of personal data records concerned by the breach; b) include the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

Furthermore, based on Article 34 paragraph 1 of Regulation 2016/679, in situations where there is a high risk of affecting the rights or freedoms of natural persons, the controller is obliged to notify the data subject of the breach without undue delay. Article 34 paragraph 2 of Regulation 2016/679 states that a proper notification should: 1) describe the nature of the personal data breach in clear and plain language; 2) include at least the information and measures referred to in Article 33 paragraph 3 letters b), c), and d) of Regulation 2016/679, i.e.: a) the name and contact details of the data protection officer or another contact point from which more information can be obtained; b) a description of the likely

consequences of the personal data breach; c) a description of the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

From the analysis of the aforementioned provisions, it follows that depending on the level of risk to the rights or freedoms of natural persons that the controller is dealing with, their obligations towards the supervisory authority, as well as towards the data subjects, are shaped differently. If, as a result of the analysis, the controller determines that the likelihood of a risk to the rights or freedoms of natural persons is low, they are not obliged to report the breach to the President of the Personal Data Protection Office. The indicated breach must only be recorded in the internal register of breaches. In the case of identifying a risk to the rights or freedoms of natural persons, the controller is obliged to report the personal data breach to the President of the Personal Data Protection Office, as well as to make an entry in the internal register of breaches. The occurrence of a high risk to the rights or freedoms of natural persons, in addition to the entry in the register of breaches, requires the controller to take appropriate actions, both towards the supervisory authority (reporting the personal data breach) and also towards the data subjects.

In the case of personal data breaches that may result in a high risk to the rights or freedoms of the data subject, Regulation 2016/679 introduces an additional obligation for the controller to promptly notify the data subject, unless they have taken preventive measures before the breach occurred or remedial actions after the breach occurred (Article 34 paragraph 3 of Regulation 2016/679).

As follows from the above, in the event of the controller detecting a personal data breach, it is first necessary to conduct an analysis regarding the occurrence of a risk to the rights or freedoms of natural persons. The controller is exempt from the obligation to notify the supervisory authority of the breach if the conducted assessment shows,

that there is at most a small probability of the risk of infringement of the rights or freedoms of natural persons. However, it should be noted that the supervisory authority may request the data controller to justify the decision not to report the breach; therefore, the conclusions from the conducted analysis should be recorded in the internal breach registry. It is worth recalling that in the Guidelines of the European Data Protection Board (EDPB) No. 9/2022[1], adopted on March 28, 2023, there are recommendations regarding the reporting of personal data breaches to the supervisory authority.

It should be emphasized that the assessment of the risk of infringement of the rights or freedoms of a natural person should be made from the perspective of the affected individual, not the interests of the data controller. This is particularly important because, based on the notification of a personal data breach, the individual can assess whether, in their opinion, the security incident may have negative consequences for them and take appropriate remedial actions. Also, based on the information provided by the data controller regarding the nature of the breach and the measures taken or proposed to remedy the breach, the individual can assess whether, following the occurrence of the personal data breach, the data controller still provides guarantees for the proper processing of their personal data in a manner that ensures its security. The lack of notification of a personal data breach to the individual in the case of a high risk of infringement of their rights or freedoms deprives them not only of the possibility of an appropriate response to the breach but also of the ability to make an independent assessment of the breach, which, after all, concerns their personal data and may have serious consequences for them. On the other hand, the lack of reporting a personal data breach deprives the supervisory authority of the ability to respond appropriately to the breach, which consists not only of assessing the risk of infringement of the rights or freedoms of the individual but also, in particular, of verifying whether the data controller has taken appropriate measures to remedy the breach and minimize the negative effects for the individuals concerned, as well as whether appropriate security measures have been implemented to minimize the risk of a recurrence of the breach.

Therefore, reporting personal data breaches by data controllers constitutes an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, data controllers inform the President of the Personal Data Protection Office (UODO) whether, in their opinion, there is a high risk of infringement of the rights or freedoms of the

individuals concerned and—if such a risk exists—whether they have provided relevant information to the individuals affected by the breach. In justified cases, they may also provide information that notification is not necessary in their opinion due to the fulfillment of the conditions specified in Article 34(3)(a) and (b) of Regulation 2016/679. The President of UODO verifies the assessment made by the data controller and may—if the data controller has not notified the individuals concerned—request such notification from them. Reporting personal data breaches allows the supervisory authority to respond appropriately, which can mitigate the effects of such breaches, as the data controller is obliged to take effective actions to ensure the protection of individuals and their personal data, which on one hand allows for the control of the effectiveness of the existing solutions, and on the other hand, the assessment of modifications and improvements aimed at preventing irregularities similar to those covered by the breach. Meanwhile, notifying individuals about the breach ensures the possibility of providing them with information about the risks associated with the breach and indicating actions that these individuals can take to protect themselves from potential negative consequences of the personal data breach (this enables the individual to make an independent assessment of the breach in the context of the possibility of materializing negative consequences for such an individual and making a decision on whether to take or not take remedial actions).

Santander Bank Polska S.A., due to the scale and nature of its activities, i.e., providing various types of financial services, processes the personal data of a very large number of clients with whom it enters into agreements for the provision of banking services. In the case under consideration, the personal data of the Bank's Clients contained in banking documentation includes: name and surname, date of birth, bank account number, residential or temporary address, PESEL identification number, email address, username and/or password, data concerning income and/or owned assets, series and number of the identity card, phone number, information about banking products, loans, bank accounts, i.e., names of agreements, dates of their conclusion, details of these products, as well as information about property insurance policies, including, among others, policy numbers, dates of issuance, sums insured, insurance premiums, information concerning the insured property, were accessed by an unauthorized person. Furthermore, data related to the conclusion of agreements and their content were also disclosed. There is also uncertainty as to whether, before the person who delivered the relevant documents to the police station, other individuals had access to these documents, as they were in a publicly accessible location. Therefore, it is beyond doubt that based on the disclosed data, the data subjects can be easily identified. Consequently, the mere assessment of the breach conducted by the data controller in terms of the risk of infringement of the rights or freedoms of natural persons is necessary to determine whether there has been a breach of data protection resulting in the obligation to notify the President of UODO (Article 33(1) and (3) of Regulation 2016/679) and of the individuals affected by the breach (Article 34(1) and (2) of Regulation 2016/679) should, as it must be emphasized once again, be assessed through the lens of the person affected by the breach. Accidental disclosure of personal data to even one identified individual can lead to an increase in the scale of the breach and thus the risk of infringement of the rights or freedoms of the data subject. At the same time, the Administrator did not demonstrate, in accordance with the principle of accountability referred to in Article 5(2) of Regulation 2016/679, that the person who found the package could be considered a so-called trusted recipient. From the explanations provided by the Bank in a letter dated September 16, 2022, it follows that it refrained from reporting the breach to the supervisory authority because "the package was found by one identified person shortly after it was lost by the courier." The risk assessment conducted was based on the belief that the person who came into possession of the package containing the Bank's documents is a so-called "honest finder," as "it was verified that no documents were missing," "the person who found the documents took them directly to the police station," and "this person admitted that they did not copy the documents." Taking the above into account, in the Administrator's opinion, "the risk assessment of the infringement of the rights and freedoms of the data subject was established at a low level."

To better illustrate cases of breaches of personal data protection resulting in accidental disclosure of data to an unauthorized person, reference should be made to Guidelines 9/2022, which indicate a case of a breach concerning data confidentiality involving the accidental disclosure of personal data to

a third party or another recipient in a situation where such data is accidentally sent to the wrong department of the organization or to a supplier organization whose services the administrator uses. The Administrator has grounds to then consider the unauthorized recipient as trusted, as they maintain a regular relationship with such an entity, know the procedures applied by them, and can trust the recipient enough to reasonably expect that the recipient will not read the mistakenly sent data or gain access to it, as well as fulfill the instruction to return it. Even in a situation where access to the data was obtained, the administrator may still trust the recipient not to take any inappropriate actions and to promptly return the data to the administrator. As further indicated by EROD, in the case described above, the administrator in the risk assessment conducted following the breach may take into account the fact that the recipient is a trusted person. However, such a situation certainly does not occur in the case under discussion. The third party who accidentally found the package containing the bank documentation, which includes very detailed personal data of the Bank's Clients, does not have any relationship with the Bank that would allow for the assumption that they are a trusted recipient, in accordance with the above position of EROD.

Referring to the above, it should be noted that it is also irrelevant that the data was disclosed to only one identified person; rather, the significant fact is that the package was found by one identified person. As previously mentioned, the Bank is uncertain how many people may have had access to the abandoned package, as it claims it was stolen during transport by the courier company, which should sufficiently influence the proper and adequate assessment of the security incident in question, including the assessment in terms of the risk of infringement of the rights or freedoms of natural persons. Even if the unauthorized recipient is a person known to the Administrator (e.g., their client who reports the mistake), there is no guarantee that this person's intentions will not change. The assessment is also not influenced by the fact of obtaining a statement from the unauthorized recipient regarding the confidentiality of the Bank's Clients' data, or as was the case in this matter – the admission that the person did not copy the documents. There is no certainty that before making the statement, this person did not make a copy or did not preserve the personal data contained in the documentation in another way, e.g., by writing it down. The Bank also has no practical means of verifying the assurance that the unauthorized recipient did not pass the Bank's Clients' data to third parties or does not possess copies of that data. Similarly, the Provincial Administrative Court in Warsaw stated in its judgment of January 21, 2022, case file II SA/Wa 1353/21, that "(...) there is no certainty that before these actions, this person did not make, for example, a photocopy or did not preserve the personal data contained in the document in another way, e.g., by writing it down. The mere performance of the actions indicated in the statements made by the Third Party - the unauthorized recipient - does not guarantee that the intentions of such a person will not change now or in the future, and the potential consequences of using such categories of data may be significant for the individuals whose data have been breached." It must be emphasized once again that the statement made by the unauthorized person does not preclude the likelihood that this breach could result in a risk of infringement of the rights or freedoms of natural persons and does not exclude the possibility that there was a high risk of infringement of the rights or freedoms of the individuals whose data are concerned.

As indicated by Guidelines 9/2022, a breach of personal data protection can potentially lead to a number of negative consequences for the individuals whose data are the subject of the breach. Among the possible consequences of the breach, EROD lists: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, breach of personal data confidentiality, and significant economic or social harm. In this case, there is no... there is no doubt that due to the scope of data covered by the infringement of personal data protection, including PESEL identification numbers along with first and last names, there is a high probability of the aforementioned damages occurring.

First and foremost, it should be emphasized that the personal data breach in question involved the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies an

individual, containing, among other things, the date of birth and gender designation, and thus is closely linked to the private sphere of the individual and is also subject to exceptional protection under Article 87 of Regulation 2016/679 – being data of a special nature that requires such special protection. The PESEL number serves as an identifying data point for each person and is commonly used in dealings with various institutions and in legal transactions. The PESEL number, along with the first and last name, unequivocally identifies the individual in a manner that allows for the attribution of negative consequences of the breach (e.g., identity theft, loan fraud) to that specific person.

Furthermore, it should be taken into account that as a result of the personal data breach in question, at least one unauthorized person was provided with these identification numbers along with the first and last names of the Bank's clients, which combination of data can be sufficient for "impersonating" the data subject and incurring financial obligations (e.g., debts) in the name and to the detriment of that subject (see: <https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusc> – where a case is described in which: “Only the first name, last name, and PESEL number were enough for the fraudsters to defraud several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the residential address”).

It is also impossible to overlook that the analyzed personal data breach – which should be emphasized – concerned a vast range of other identifying data of these individuals, such as contact details (which are commonly understood to include residential or temporary addresses, phone numbers, and email addresses), dates of birth, bank account numbers, series and numbers of identity cards, usernames and/or passwords, data regarding earnings and/or owned assets, or the contents of the contracts concerning banking products (contract names, dates of their conclusion, details of these products) and a range of information related to property insurance policies (including policy numbers, dates of issuance, sums insured, insurance premiums, information regarding the insured property).

In assessing the risk, a key factor is the type and sensitivity of the personal data disclosed as a result of the breach. The Guidelines 9/2022 emphasize that a collection of various personal data typically has a more sensitive nature than individual data.

It is worth citing one of the examples found in the Guidelines of the European Data Protection Board 01/2021[2] (case no. 14, p. 31), referring to the situation of “accidentally mailing highly confidential personal data.” In the case described in the aforementioned guidelines, there was a disclosure of a social security number, which is equivalent to the PESEL number used in Poland. In this case, the EDPB had no doubt that the disclosed data regarding: first name and last name, email address, postal address, and social security number indicated a high risk of infringement of the rights or freedoms of individuals (“the involvement of their [the affected individuals] social security number, as well as other, more basic personal data, additionally increases the risk that can be described as high”). The EDPB recognizes the importance of national identification numbers (in this case, the PESEL number), while also emphasizing that this type of personal data breach, thus encompassing data in the form of: first name and last name, email address, postal address, and social security number, requires the implementation of actions, i.e., notifying the supervisory authority and informing the affected individuals about the breach.

The European Data Protection Board has no doubt that an individually assigned number that uniquely identifies an individual should be subject to special protection, and its disclosure to unauthorized entities may involve a high risk of infringement of the rights or freedoms of individuals.

The fact that data that unequivocally identifies an individual may cause a high risk of infringement of rights or freedoms is also indicated by the EDPB in other examples provided in the Guidelines 01/2021. In points 65 and 66 of the Guidelines 01/2021, it is stated: “(...) The breached data allows for the unequivocal identification of the individuals to whom the data pertains and contains other information about them (including gender, date and place of birth); moreover, they may be used by an attacker to guess customers' passwords or to conduct a spear-phishing campaign directed at the bank's customers. For these reasons, it was considered that the data breach would likely cause a high risk of infringement of the rights and freedoms of all individuals whose data is concerned.

Consequently, material damages (e.g., financial losses) and non-material damages (e.g., identity theft or fraud) may occur.”

Similar doubts (that the disclosure of the PESEL number along with other personal data may cause a high risk of infringement of the rights or freedoms of individuals) were also held by the Provincial Administrative Court in Warsaw, which in its judgment of September 22, 2021, case file II SA/Wa 791/21, stated that “There is no doubt that the examples of damages cited in the guidelines may occur in the case of individuals whose personal data – in some cases...

including the identification number PESEL or the series and number of the identity card – have been recorded on the provided recordings. The possibility of identifying individuals whose data has been compromised based on the disclosed information is significant for such an assessment.” Furthermore, the Court in the cited ruling indicated that “The data was made available to unauthorized persons, which means that a security breach occurred leading to the unauthorized disclosure of personal data, and the scope of this data, which in some cases also includes the PESEL identification number or the series and number of the identity card, determines that there was a high risk of violation of the rights or freedoms of natural persons.” Considering the above issues, it is also necessary to refer to the position of the Provincial Administrative Court in Warsaw expressed in the judgment of July 1, 2022, in case file II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: “It should be agreed with the President of the UODO that the loss of confidentiality of the PESEL number in conjunction with personal data, such as: first name and surname, registered address, bank account numbers, and the identification number assigned to Bank clients - CIF number, is associated with a high risk of violation of the rights or freedoms of natural persons. In the event of a breach of such data as first name, surname, and PESEL number, identity theft or forgery may occur, resulting in negative consequences for the individuals concerned. Therefore, the Bank in this matter should have promptly notified the individuals whose data is concerned about the breach of personal data protection, in accordance with Article 34(1) of the GDPR, so as to enable them to take necessary preventive actions” (emphasis added). It should also be noted the judgment of August 31, 2022, case file II SA/Wa 2993/21, in which the Provincial Administrative Court in Warsaw emphasized that “(...) the authority correctly assumed that there was a high risk of violation of the rights and freedoms of individuals affected by the breach due to the possibility of easy identification of the individuals whose data was compromised based on the disclosed information. This data includes first name and surname, correspondence address, phone number, and PESEL number of individuals holding Polish citizenship. In this situation, the administrator was obliged to notify without undue delay the individuals whose data is concerned about the breach.” Similarly, the Provincial Administrative Court in Warsaw expressed itself in judgments of November 15, 2022, case file II SA/Wa 546/22, June 21, 2023, case file II SA/Wa 150/23, and November 6, 2023, case file II SA/Wa 996/23.

In light of the above, it is also worth recalling the judgment of the Supreme Administrative Court in Warsaw of December 6, 2023, case file III OSK 2931/21, in which it was stated: “The President of the UODO correctly established that there was a disclosure of data, including first names and surnames, as well as PESEL numbers of natural persons, and thus relatively permanent, unchanging data, the disclosure of which may always pose a risk of negative consequences for the aforementioned individuals. Similarly, residential addresses are personal data, the unauthorized disclosure of which creates a probability of a high risk of negative legal consequences, regardless of the fact that the disclosure of addresses occurred several years after their update.”

From the latest infoDOK report[3] (which is prepared as part of the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and some banks, under the patronage of the Ministry of Internal Affairs and Administration and in cooperation with, among others, the Police and the Consumers' Federation), it follows that in the third quarter of 2023 alone, there were 2,587 attempts to defraud loans and credits for a total amount of PLN 104.1 million. In the entire year of 2021, there were 8,096 attempts to defraud loans for a total amount of PLN 336.6 million, while in the entire year of 2022, there were 8,079 attempts to defraud loans. Furthermore, as indicated by judicial rulings, judgments in cases of loan fraud are not uncommon and have been

issued by Polish courts in similar cases for a long time. For example, one can refer to the judgment of the District Court in Łęczyca of July 27, 2016 (case file I C 566/15), in which fraudsters taking a loan using someone else's data used the PESEL number, a fictitious address, and an incorrect identity card number (invalid). In the justification of the aforementioned judgment, the Court stated that: "The conducted evidentiary proceedings and the analysis of documents submitted by the plaintiff result in a clear conclusion that in the case at hand, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used when concluding it, the indicated place of residence does not correspond to the residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of the conclusion of the loan agreement, the identity card number (...) lost its validity on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by the defendant."

In another case (I C 693/16), the District Court in Zgierz in its judgment of November 4, 2016, ruled: "The personal data of the defendant in the form of his first name and surname and PESEL number, which were consistent with the defendant's data, did not indicate that the defendant submitted a declaration of will to conclude a loan agreement on December 17, 2014. It is possible that a person who unlawfully gained access to the personal data of the defendant concluded a loan agreement on his behalf with the company (...) sp. z o.o. S.K.A. based in W. In this case, the defendant demonstrated that he had never lived at the address indicated in the loan agreement and that the phone number and email address used to register on the website...

of probability of occurrence of a data breach, combined with the severity of potential negative consequences for the affected individuals, may lead to the obligation to report the breach to the relevant supervisory authority.

In summary, the legal framework surrounding data protection emphasizes the importance of safeguarding personal data and ensuring that any breaches are addressed promptly and effectively. The courts have consistently ruled that the mere possession of personal data does not suffice to establish the validity of agreements made under potentially fraudulent circumstances.

This underscores the necessity for thorough verification processes, especially in cases involving online transactions, where the risk of identity theft and fraud is heightened. The responsibility of the data controller is to ensure compliance with the regulations and to act in the best interest of the individuals whose data is being processed.

In conclusion, the protection of personal data is not only a legal obligation but also a fundamental right that must be upheld to maintain trust and integrity in financial and legal transactions.

any of these factors affects the overall assessment, which is a prerequisite for fulfilling, among others, the obligation specified in Article 33(1) of Regulation 2016/679. Considering that due to the scope of the disclosed personal data in the analyzed case, there was a possibility of serious negative consequences materializing for the individuals concerned, the weight of the potential impact on the rights or freedoms of natural persons should be regarded as high. At the same time, the likelihood of a high risk occurring as a result of the breach in question is not small and has not been eliminated. Therefore, it should be stated that in connection with the breach in question, there is a high risk of infringement of the rights or freedoms of the individuals concerned, which consequently determines the obligation to report the personal data breach to the supervisory authority.

In Guidelines 9/2022, the EDPB indicates the factors to be considered when assessing risk, referring to recitals 75 and 76 of Regulation 2016/679, which suggest that the controller should take into account both the likelihood of occurrence and the severity of the threat to the rights or freedoms of the data subject. In the case of a personal data breach, the controller should focus on the risk of impact on the individual arising from the breach. Thus, when assessing the risk to the individual resulting from the personal data breach, the controller should consider the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence. In this regard, when assessing risk, the EDPB recommends considering criteria such as: the type of breach, the nature, sensitivity, and amount of personal data, as well as the ease of identification, as these may affect the

level of risk to individuals. The risk of infringement of the rights and freedoms of a natural person, according to Guidelines 9/2022, will be greater when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. The guidelines indicate that in case of any doubts, the controller should report the breach, even if such caution might seem excessive.

In summary of the above considerations, it should be stated that in the present case, there is a high risk of infringement of the rights or freedoms of the individuals affected by the breach, which in turn results in the Bank's obligation to report the personal data breach to the supervisory authority, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified in Article 33(3) of Regulation 2016/679, as well as notifying the individuals about the breach, in accordance with Article 34(1) of Regulation 2016/679, which must include the information specified in Article 34(2) of Regulation 2016/679. The Bank, due to the nature of its activities, processes personal data on a large scale and should be aware of the legal obligations arising from the identification of a personal data breach. Informing the Controller about their obligations regarding personal data protection, as well as advising the Controller, is also part of the tasks of the appointed Data Protection Officer in the Bank. The Bank should also possess knowledge in this area due to a previously issued decision imposing an administrative fine for the infringement of Article 34(1) of Regulation 2016/679, consisting of failing to notify without undue delay the individuals concerned about the personal data breach (decision of January 19, 2022, reference number (...)), especially since the Controller's complaint against this decision was dismissed by the judgment of the Provincial Administrative Court in Warsaw on November 15, 2022 (reference number II SA/Wa 546/22).

Referring to the obligation of the Controller specified in Article 34(2) of Regulation 2016/679, the President of the UODO stated that the Controller (considering the nature of the breach and the categories of data that were breached) should indicate to the individuals concerned the most likely negative consequences of the breach of their personal data. Certainly, in the case of a breach of such data as first names, last names, and PESEL identification numbers, it is necessary to primarily indicate the possible theft or falsification of identity through obtaining loans from non-bank institutions or fraudulently obtaining insurance or funds from insurance, which may lead to negative consequences related to the attempt to attribute to the individual whose data has been breached the responsibility for committing such fraud. The description of possible consequences should reflect the risk of infringement of the rights or freedoms of that individual, so as to enable them to take necessary preventive actions.

In a situation where, as a result of a personal data breach, there is a high risk of infringement of the rights or freedoms of natural persons, the controller is obliged to implement all appropriate technical and organizational measures to immediately identify the personal data breach and quickly inform the supervisory authority, as well as the individuals concerned. The controller should fulfill this obligation as soon as possible.

Recital 85 of the preamble to Regulation 2016/679 explains: "In the absence of appropriate and timely response, a personal data breach may result in physical harm, material or non-material damage to natural persons, such as loss of control over their personal data or restriction of rights, discrimination, identity theft or falsification, financial loss, unauthorized reversal of pseudonymization, damage to reputation, breach of confidentiality of personal data protected by professional secrecy or... all other significant economic or social damages. Therefore, immediately upon discovering a personal data breach, the controller should report it to the supervisory authority without undue delay, if feasible, no later than 72 hours after the breach is identified, unless the controller can demonstrate in accordance with the accountability principle that the breach is unlikely to result in a risk to the rights or freedoms of natural persons. If it is not possible to report within 72 hours, the notification should be accompanied by an explanation for the delay, and information may be provided gradually, without further undue delay.

In turn, Recital 86 of the preamble to Regulation 2016/679 states: "The controller should inform the data subject without undue delay of a personal data breach if it is likely to result in a high risk to the

rights or freedoms of that person, so as to enable that person to take the necessary protective measures. Such information should include a description of the nature of the personal data breach and recommendations for the data subject on minimizing the potential adverse effects. Information should be provided to the data subjects as soon as reasonably feasible, in close cooperation with the supervisory authority, respecting the guidance provided by that authority or other relevant bodies, such as law enforcement authorities. For example, the need to minimize the immediate risk of harm will require notifying the data subjects without delay, while the implementation of appropriate measures against similar or related personal data breaches may justify a later notification."

By notifying the data subject without undue delay, the controller enables the individual to take the necessary protective measures to safeguard their rights or freedoms against the negative consequences of the breach. Article 34(1) and (2) of Regulation 2016/679 aims not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see Witold Chomiczewski [in:] GDPR. General Data Protection Regulation. Commentary, ed. E. Bielak-Jomaa, D. Lubasz, Warsaw 2018). Proper compliance with the obligation set out in Article 34 of Regulation 2016/679 is intended to provide data subjects with quick and transparent information about the breach of their personal data, along with a description of the possible consequences of the personal data breach and the measures they can take to minimize its potential negative effects. By acting in accordance with the law and demonstrating care for the interests of the data subjects, the controller should have ensured, without undue delay, that the data subjects had the best possible protection of their personal data. To achieve this goal, it is essential at least to indicate the information listed in Article 34(2) of Regulation 2016/679, which the Bank failed to fulfill. By deciding not to notify the supervisory authority and the data subjects about the breach, the controller effectively deprived the data subjects of timely, reliable information about the breach of their personal data and the opportunity to counter potential damages.

Consequently, it should be stated that the Controller did not report the personal data breach to the supervisory authority in fulfillment of the obligation under Article 33(1) of Regulation 2016/679 and did not notify the data subjects without undue delay about the breach of their data protection, in accordance with Article 34(1) of Regulation 2016/679, which constitutes a violation by the Controller of these provisions.

At this point, it should be noted that according to Article 34(4) of Regulation 2016/679, if the controller has not yet notified the data subject about the personal data breach, the supervisory authority—considering the likelihood that the personal data breach will result in a high risk—may require the controller to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Furthermore, from the content of Article 58(2)(e) of Regulation 2016/679, it follows that each supervisory authority has the corrective power to order the controller to notify the data subject about the personal data breach.

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. The President of the UODO states that in the case at hand, there were grounds justifying the imposition of an administrative fine on the Bank based on Article 83(4)(a) of Regulation 2016/679, which states, among other things, that a breach of the obligations of the controller referred to in Articles 33 and 34 of Regulation 2016/679 is subject to an administrative fine of up to 10,000,000 EURO, and in the case of an enterprise—up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable.

Pursuant to Article 83(2) of Regulation 2016/679, administrative fines are imposed, depending on the circumstances of each individual case, in addition to or instead of the measures referred to in Article 58(2)(a) - (h) and (j) of Regulation 2016/679. In deciding to impose an administrative fine on the Bank, the President of the UODO—according to the provisions of Article 83(2)(a) - (k) of Regulation 2016/679—considered the following...

the case circumstances that necessitate the application of this type of sanction in the present case and that adversely affect the assessment of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In this case, a violation of Article 33(1) of Regulation 2016/679 was identified (consisting of the failure to notify the President of the Personal Data Protection Office of a personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach) as well as Article 34(1) of Regulation 2016/679 (consisting of the failure to inform the individuals concerned about the personal data breach without undue delay). These violations are related to an event involving the disclosure of personal data of Bank customers, including: first names and surnames, dates of birth, bank account numbers, residential or temporary addresses, PESEL identification numbers, email addresses, usernames and/or passwords, income and/or asset information, series and numbers of identity documents, phone numbers, information about banking products, loans, bank accounts, i.e., names of contracts, dates of their conclusion, details of these products, information about property insurance policies, including but not limited to policy numbers, dates of issuance, sums insured, insurance premiums, information regarding the insured property, as a result of the theft of a shipment containing Bank documentation during its transport by a courier company, and subsequently the abandonment of the opened shipment in a public place, resulting in unauthorized access to the documentation by at least one unauthorized person. This event is of significant weight and serious nature, as it may lead to material or non-material damages for the individuals whose data has been breached, and the likelihood of such damages occurring is high. In connection with the occurrence of the personal data breach, consisting of the loss of a shipment containing banking documentation, there was an unlawful disclosure of information covered by banking secrecy, which further increases the severity of the breach and indicates the possibility of negative consequences of the event for the individuals whose data is concerned.

Additionally, it should be considered an aggravating circumstance that the breach, consisting of the failure to notify individuals about the breach of their personal data, involved the personal data of many individuals, as it concerned 158 persons, and although there is no evidence in this case that the individuals whose data was accessed by the unauthorized person suffered material damage, the mere breach of the confidentiality of their data constitutes non-material damage (harm) for them. Individuals whose data was unlawfully obtained may at least feel apprehensive about losing control over their personal data, identity theft or identity fraud, discrimination, or ultimately financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, the fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of *Natsionalna agentsia za prihodite (C-340/21)* emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which the data subject experiences as a result of a breach of this regulation, may in itself constitute non-material damage within the meaning of this provision."

The President of the Personal Data Protection Office also considers the prolonged duration of the Bank's violation of the provisions of Regulation 2016/679 as an aggravating circumstance, as it should be emphasized that the state of violation, which is the basis for these proceedings, still persists, and the violation itself is continuous. The Bank has still not reported the breach, which justifies the low risk of violation of the rights or freedoms of the affected individuals; it also did not notify individuals about the breach of their personal data. Furthermore, the information about the personal data breach, i.e., the discovery of abandoned documents belonging to Bank customers, was obtained by the Administrator on November 24, 2018, thus over the years, the risk of violation of the rights or freedoms of the individuals affected by the breach could have materialized, and these individuals could not counteract it due to the Bank's failure to fulfill its obligation to report the personal data breach to the President of the Personal Data Protection Office and to notify the individuals concerned about it.

2. The intentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). According to the

Guidelines of the Article 29 Working Party on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, and approved by the EDPB on May 25, 2018), intent "includes both knowledge and deliberate action, in connection with the characteristics of the prohibited act." The Bank made a conscious decision not to notify the President of the Personal Data Protection Office about the breach, as well as the individuals whose data is concerned. There is no doubt that the Bank, processing personal data on a large scale, must have knowledge in the area of personal data protection, including knowledge of the consequences of identifying a personal data breach resulting in a high risk of violation of the rights or freedoms of individuals (and this knowledge can be required not only from the administrator but also from the data protection officer appointed by them). Undoubtedly, the source of knowledge for the Bank regarding the obligations related to the personal data breach is also the decision of the President.

Office of Personal Data Protection dated January 19, 2022 (described below in point 3), to which the Bank's complaint was dismissed by the judgment of the Provincial Administrative Court in Warsaw dated November 15, 2022 (case file II SA/Wa 546/22). The administrative fine imposed by the aforementioned decision, along with a comprehensive justification in which the President of the UODO cited applicable regulations and guidelines, contains necessary information regarding the Administrator's obligations related to the identified breach of personal data protection. It can therefore be concluded that the Administrator, being aware of the responsibilities imposed on him, neglected his obligations related to the breach of data protection and failed to report the breach of personal data protection to the President of the UODO and to notify the data subjects about the breach. Finally, the mere initiation by the President of the UODO of these proceedings regarding the obligation to report a breach of personal data protection to the supervisory authority and to notify the data subjects about the breach should have raised at least doubts for the Administrator regarding the correctness of his position.

3. Any relevant prior breaches by the administrator or processor (Article 83(2)(e) of Regulation 2016/679). When deciding on the imposition and amount of the administrative fine, the supervisory authority is obliged to pay attention to any prior breaches of Regulation 2016/679. The EDPB in Guidelines 04/2022 on calculating administrative fines under the GDPR adopted on May 24, 2023, explicitly states: "The existence of prior breaches may be considered an aggravating factor when calculating the amount of the fine. The weight attributed to this factor should be determined taking into account the nature and frequency of the prior breaches. However, the absence of prior breaches cannot be considered a mitigating circumstance, as compliance with the provisions of [Regulation 2016/679] is the norm" (point 94 of the guidelines).

The President of the UODO had previously conducted administrative proceedings against the Bank (described further in this point) regarding the breach of the obligation arising from Article 34(1) of Regulation 2016/679 due to the failure to notify, without undue delay, the data subjects about the breach of personal data protection. By decision dated January 19, 2022, case file (...), the President of the UODO imposed an administrative fine of 545,748 PLN on the Bank for violating this provision of Regulation 2016/679. The above decision, as mentioned in point 2, was upheld by the judgment of the Provincial Administrative Court in Warsaw dated November 15, 2022, dismissing the Bank's complaint (due to the filing of a cassation complaint by the Bank, the case is currently awaiting resolution by the Supreme Administrative Court). The repeated violation of the provisions of Regulation 2016/679 by failing to notify, without undue delay, the data subjects about the breach of personal data protection, as well as the failure to notify the President of the UODO about the identified breach of personal data protection, indicates the Bank's dismissive approach to its obligations related to personal data processing, trivializing the incident and failing to recognize its impact on the Data Subjects. The violation of the provisions of Regulation 2016/679, which is the subject of these proceedings, not being a one-time occurrence as indicated, deserves a negative assessment, which is expressed by the imposition of an administrative fine on the Bank.

According to the EDPB Guidelines 04/2022, "Although all prior breaches may provide information

about the overall approach of the administrator or processor to compliance with the GDPR, greater significance should be attributed to breaches concerning the same subject matter, as they are closer to the breach that is the subject of the current proceedings, especially when the administrator or processor has previously committed the same breach (repeated breaches)” (point 88 of the guidelines). “Above all, the timing of the prior breach should be taken into account, considering that the longer the time between that breach and the breach that is the subject of the current proceedings, the less significance that prior breach has” (point 84 of the guidelines). Given that the supervisory authority has already conducted proceedings against Santander Bank Polska S.A. regarding the violation of Article 34(1) of Regulation 2016/679, which resulted in the issuance of a decision imposing an administrative fine, this circumstance should undoubtedly be considered as an aggravating factor in determining the amount of the imposed administrative fine.

Furthermore, the supervisory authority has identified in other issued administrative decisions violations by the Administrator of personal data protection regulations: - in the decision dated December 17, 2020 (case file (...)) violation of Article 6(1) and Article 21(3) in connection with Article 12(3) of Regulation 2016/679; - in the decision dated April 22, 2021 (case file (...)) violation of Article 6(1) in connection with Article 5(1)(f) of Regulation 2016/679; - in the decision dated June 29, 2022 (case file (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision dated June 30, 2022 (case file (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision dated July 7, 2022 (case file (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision dated August 19, 2022 (case file (...)) violation of Article 15(1) in connection with Article 12(3) of Regulation 2016/679; - in the decision dated August 30, 2022 (case file (...)) violation of Article 15(1) in connection with Article 12(3) of Regulation 2016/679; - in the decision dated September 28, 2022 (case file (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision dated 10 November 2022 (case no. (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision of 18 November 2022 (case no. (...)) violation of Article 12(3) in conjunction with Article 15(3) of Regulation 2016/679; - in the decision of 9 January 2023 (case no. (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision of 22 August 2023 (case no. (...)) violation of Article 6(1) in conjunction with Article 21(2) and (3) of Regulation 2016/679; - in the decision of 22 September 2023 (case no. (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision of 8 December 2023 (case no. (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision of 23 January 2024 (case no. (...)) violation of Article 6(1) of Regulation 2016/679; - in the decision of 30 January 2024 (case no. (...)) violation of Article 6(1) of Regulation 2016/679.

The violations described above are significant, as they resulted in the supervisory authority applying remedial measures, which affect the final amount of the penalty imposed on the Administrator. The supervisory authority sees a connection between the previously identified violations and the currently analyzed violations, such as the similar *modus operandi* of the Bank, which involved deliberately failing to provide certain personal data and information to authorized entities, as occurred, for example, in the case of the violation of Article 15(1) and Article 34(1) of Regulation 2016/679, or even the frequency of violations of data protection regulations committed by the Administrator. As can be seen from the list of decisions issued by the President of the UODO above, in the last four months, the supervisory authority has already issued three decisions in which it applied a remedial measure against Santander Bank Polska S.A.

Therefore, the issuance of numerous warnings, followed by the imposition of a financial penalty in the case with reference no. (...), justifies not only the imposition of a financial sanction in this proceeding but also its high amount.

In light of the above, it should be recognized in this case that there are grounds to treat the criterion from Article 83(2)(e) of Regulation 2016/679 as aggravating.

4. The degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). In this case, the President of the UODO found the cooperation from the Bank to be unsatisfactory. This assessment concerns the Administrator's response to letters from the President of the UODO informing about the

obligations imposed on the administrator in connection with the data protection violation, or finally regarding the initiation of administrative proceedings concerning the obligation to report the personal data breach and notify the affected individuals. The actions deemed correct by the President of the UODO (reporting the breach to the President of the UODO and notifying the individuals affected by the breach) were not taken by the Bank even after the President of the UODO initiated administrative proceedings in the matter.

5. Categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679). The disclosed personal data do not belong to the special categories of personal data referred to in Article 9(1) of Regulation 2016/679, nor to the data specified in Article 10 of Regulation 2016/679; however, the fact that the abandoned documentation contained a wide range of data in the form of: name and surname, date of birth, bank account number, residential or temporary address, PESEL identification number, email address, username and/or password, data concerning earnings and/or owned assets, series and number of the identity card, telephone number, information about banking products, loans, bank accounts, i.e., names of contracts, dates of their conclusion, details of these products, as well as information about property insurance policies, i.e., including policy numbers, dates of issuance, sums insured, insurance premiums, information concerning the insured property, is associated with a high risk of infringement of the rights or freedoms of natural persons. The PESEL number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing the date of birth, ordinal number, gender designation, and control number, is therefore closely linked to the private sphere of the individual and is also subject, as a national identification number, to special protection under Article 87 of Regulation 2016/679, being data of a special nature that requires such special protection. There is no other, so specific data that would unequivocally identify a natural person. It is not without reason that the PESEL number serves as identifying data for every individual and is widely used in dealings with various institutions and in legal transactions. The PESEL number, along with the name and surname, uniquely identifies a natural person in a way that allows negative consequences of the violation (e.g., identity theft, loan fraud) to be attributed to that specific individual.

In this context, it is worth recalling the EDPB Guidelines 04/2022, which state: "Regarding the requirement to take into account the categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679), the [Regulation 2016/679] explicitly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing financial penalties. This applies at least to the types of data covered by Articles 9 and 10 of [Regulation 2016/679] and to data not covered by the scope of those articles, the dissemination of which immediately causes harm or discomfort to the individual concerned (e.g., data concerning location, data concerning private communication, national identification numbers...

identifying or financial data, such as transaction statements or credit card numbers). Generally speaking, the greater the number of such categories of data involved in the breach or the more sensitive the data, the more weight the supervisory authority may assign to such a factor. The amount of data concerning each individual whose data is affected is also significant, as the scale of the breach of privacy rights and personal data protection increases with the amount of data concerning each individual whose data is affected.

It is worth noting once again the developing case law in this area, where, for example, in the judgment of November 15, 2022, case reference II SA/Wa 546/22, the Regional Administrative Court in Warsaw stated: "It was also obvious that when determining the amount of the penalty, the authority had to take into account the fact that the breach concerned data of great sensitivity (including PESEL, address, health status data)." This view was also shared by the aforementioned Court in the judgment of June 21, 2023, in case reference II SA/Wa 150/23, where the Regional Administrative Court in Warsaw indicated: "In summary, the Court holds that the disclosure of the PESEL number indicates a high risk of infringement of the rights or freedoms of natural persons."

In determining the amount of the administrative monetary penalty, the President of UODO found no grounds to consider mitigating circumstances that would affect the final amount of the penalty. All the criteria listed in Article 83(2)(a)-(j) of Regulation 2016/679, in the opinion of the supervisory authority,

constitute either aggravating factors or are merely neutral.

Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires consideration of any other aggravating or mitigating factors applicable to the circumstances of the case), no mitigating circumstances were found.

Other circumstances, as indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified breach in this case, were deemed by the President of UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty:

1. Actions taken by the controller to minimize the damage suffered by the individuals whose data is concerned (Article 83(2)(c) of Regulation 2016/679). Based on the evidence gathered in the case, no such actions were taken by the Administrator.
2. The degree of responsibility of the controller, taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The breach of the provisions of Regulation 2016/679 assessed in this proceeding (failure to report the breach of personal data protection to the President of UODO and failure to notify the individuals whose data is concerned about the breach of personal data protection) is not related to the technical and organizational measures applied by the controller.
3. The manner in which the supervisory authority became aware of the breach (Article 83(2)(h) of Regulation 2016/679). The President of UODO was not informed about the breach of personal data protection that is the subject of this case in accordance with the procedure provided for such situations as specified in Article 33 of Regulation 2016/679. The President of UODO became aware of the breach related to the incident involving the disclosure of personal data of Bank clients, resulting from the theft of a shipment containing banking documentation concerning 158 individuals during its transport by a courier company, and subsequently abandoning the opened shipment in a publicly accessible place, which allowed an unauthorized person to access the documentation, through a report on the portal (...), where the incident of "leakage of bank client documents" was described, which "were found scattered in a cardboard box in a closed housing estate in K." The lack of reporting the breach of personal data protection to the supervisory authority and notifying the individuals whose data is concerned about the breach of personal data protection is the sole subject of this proceeding, and in the circumstances of the considered factual state, the supervisory authority accepted that it would not treat this criterion as an aggravating circumstance.
4. Compliance with previously applied measures in the same case, as referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the Administrator in the case under consideration, which means that the Administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of UODO, could have had an aggravating or mitigating effect on the assessment of the identified breach.
5. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Administrator does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for controllers and processors, as provided by the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as means guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.
6. Financial benefits obtained directly or indirectly in connection with the breach or losses avoided. (Article 83, paragraph 2, letter k of Regulation 2016/679). The President of the UODO did not find that

the Administrator derived any financial benefits or avoided any losses as a result of the violation. Therefore, there are no grounds to consider this circumstance as aggravating for the Administrator. The determination of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the lack of such benefits achieved by the Administrator, as a natural state independent of the violation and its effects, is a circumstance that inherently cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83, paragraph 2, letter k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" – that occurred on the part of the entity committing the violation.

The President of the UODO does not see any other aggravating or mitigating factors applicable to the circumstances of this case.

In the opinion of the President of the UODO, the administrative monetary penalty applied fulfills, in the established circumstances of this case, the functions referred to in Article 83, paragraph 1 of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case.

Taking into account the administrative monetary penalty imposed on the Bank by the previous decision of the President of the Personal Data Protection Office (case no. (...)), it should be assumed that its amount was not effective; therefore, the President of the UODO decided to increase the amount of the penalty imposed by this decision. The penalty will be effective if its imposition leads to the Bank, which processes personal data professionally and on a large scale, fulfilling its obligations regarding personal data protection in the future, particularly in terms of reporting personal data breaches to the President of the UODO and notifying the individuals affected by the breach.

In the opinion of the President of the UODO, the administrative monetary penalty will serve a repressive function, as it will constitute a response to the Bank's violation of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of the UODO, it will indicate both to the Bank and to other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of personal data breaches, which aim to prevent their negative and often severe consequences for the individuals affected by the breach, as well as to eliminate these consequences or at least mitigate them.

Pursuant to Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo," the equivalent amounts expressed in euros, referred to in Article 83 of Regulation 2016/679, are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Having the above in mind, the President of the UODO, based on Article 83, paragraph 4, letter a) in conjunction with Article 103 of the uodo, for the violation described in the operative part of this decision, imposed on the Bank – applying the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 1,440,549 PLN (which is equivalent to 330,000 EUR).

In the opinion of the President of the UODO, the imposed monetary penalty in the amount of 1,440,549 PLN (in words: one million four hundred forty thousand five hundred forty-nine zlotys) meets, in the established circumstances of this case, the criteria referred to in Article 83, paragraph 1 of Regulation 2016/679 due to the seriousness of the established violation in the context of the fundamental objective of Regulation 2016/679 – the protection of fundamental rights and freedoms of natural persons, in particular the right to personal data protection. Referring to the amount of the administrative monetary penalty imposed on the Bank, the President of the UODO considered that it is proportional to the financial situation of the Administrator and will not constitute an excessive burden for him.

The "Annual Report of Santander Bank Polska S.A. for 2022" presented by the Administrator indicates that the total revenues of the Bank (i.e., interest, commissions, and dividends) in 2022 amounted to 13,061,886,000 PLN, which means that the amount of the administrative monetary penalty imposed in this case constitutes approximately 0.01% of the aforementioned revenue.

At the same time, it is worth emphasizing that the amount of the imposed penalty of 1,440,549 PLN is only 0.55% of the maximum penalty that the President of the UODO could impose on the Bank for the violations established in this case, applying the maximum penalty of up to 2% of the total annual turnover from the previous financial year (i.e., 261,237,720 PLN) in accordance with Article 83, paragraph 4 of Regulation 2016/679.

The amount of the penalty has been set at such a level that, on the one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, while on the other hand, it does not create a situation in which the necessity to pay the financial penalty would lead to negative consequences, such as a significant reduction in employment or a substantial decline in the Bank's turnover.

In the opinion of the President of the UODO, the Bank should and is able to bear the consequences of its negligence in the area of data protection, as evidenced by the Annual Report of the Bank submitted to the President of the UODO on January 5, 2024.

At the same time, the President of the UODO, based on Article 83, paragraph 3 of Regulation 2016/679, decided to impose one penalty for two violations attributed.

Administrator in the proceedings regarding case no. DKN.5131.59.2022. The source of both violations is the same event, namely the loss of a shipment containing banking documents with customer data of the Bank, and the subsequent decision of the Bank not to report this fact to the President of the UODO and not to notify the individuals whose data is concerned about the breach of personal data protection. These events are contextually, spatially, and temporally so interconnected that, in accordance with the EROD Guidelines No. 4/2022 on calculating administrative fines under the GDPR, they should be treated as a single act of the administrator, leading to the imposition of a single monetary penalty (point 28 of the guidelines).

Finally, it is necessary to indicate that in determining the amount of the administrative fine in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in the Guidelines 04/2022 regarding the calculation of administrative fines under the GDPR adopted on May 24, 2023. According to the guidance presented in this document:

1. The President of the UODO categorized the violations of the provisions of Regulation 2016/679 identified in this case (see Chapter 4.1 of the Guidelines 04/2022). The violations identified in this case of both provisions of Regulation 2016/679 (Article 33(1) and Article 34(1)) fall—according to Article 83(4)(a) of Regulation 2016/679—into the category of violations subject to a lower penalty of the two dimensions provided for in Regulation 2016/679 (with a maximum amount of up to EUR 10,000,000 or up to 2% of the total annual turnover of the enterprise from the previous financial year). They have therefore been in abstracto (independently of the individual circumstances of the specific case) recognized by the EU legislator as less serious than the violations indicated in Article 83(5) of Regulation 2016/679.

2. The President of the UODO assessed the violations identified in this case as violations of low severity (see Chapter 4.2 of the Guidelines 04/2022). In this assessment, the factors among those listed in Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violations (constituting the "seriousness" of the violation), namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data concerned by the violations (Article 83(2)(g) of Regulation 2016/679) were taken into account. A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violations identified in this case treated as a whole leads to the conclusion that their severity level is also low in concreto (on the scale of severity of violations

presented in point 60 of the Guidelines 04/2022). Consequently, this results in the acceptance— as the starting amount for calculating the fine—of a value falling within the range of 0 to 10% of the maximum amount of the fine that can be imposed on the Bank. Given that Article 83(4) of Regulation 2016/679 obliges the President of the UODO to take as the maximum amount of the fine for the violations indicated in this provision the amount of EUR 10,000,000 or—if this amount is higher than EUR 10,000,000—the amount representing 2% of the Company's turnover from the previous financial year, the President of the UODO concluded that the so-called dynamic maximum fine amount applies in this case—EUR 59,844,162—resulting from the application of a 2% rate applied to the Bank's turnover for 2022, which amounted to EUR 2,992,208,096 (equivalent to PLN 13,061,886,000). Having at his disposal a range from 0 to EUR 59,844,162, the President of the UODO accepted, as adequate and justified by the circumstances of the case, the starting amount for calculating the fine to be EUR 2,393,766,000 (constituting 4% of the dynamic maximum fine amount).

3. In accordance with the guidance of the European Data Protection Board presented in point 66 of the Guidelines 04/2022 (regarding enterprises with an annual turnover exceeding EUR 500 million), the President of the UODO did not find it appropriate to take advantage of the possibility of reducing the starting amount based on the assessment of the severity of the violation, which this guideline (in Chapter 4.3) provides for smaller enterprises and those with less economic power. The EROD indicates therein that in the case of large entities (which the Bank undoubtedly is in this case, as evidenced by its turnover), "the size of the enterprise is already reflected in the dynamic statutory maximum amount" (point 66 of the Guidelines 04/2022).

4. The President of the UODO assessed the impact on the identified violation of the remaining circumstances (besides those taken into account above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of the Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate—as the Guidelines 04/2022 assume—to the subjective side of the violation, that is, to the entity itself that committed the violation and to its behavior before the violation, during its occurrence, and after it took place. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The President of the UODO concluded (which was justified in the part of the reasoning of the decision presented above) that the aggravating circumstances in this case, and consequently additionally increasing the amount of the fine imposed by this decision, are the relevant previous violations identified by the President of the UODO on the part of the Bank (Article 83(2)(e) of Regulation 2016/679), as well as the degree of cooperation of the Bank with the President of the UODO in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The remaining factors (from Article 83(2)...

2 lit. c), d), h), i), j), k) of Regulation 2016/679) – as indicated above – had no impact, either mitigating or aggravating, on the assessment of the violation and consequently on the imposition of the penalty. Due to the existence of additional aggravating circumstances in the case, related to the subjective aspect of the violations (the assessment of the Bank's conduct before and after the violations), the President of the Personal Data Protection Office (UODO) deemed it appropriate to increase the amount of the penalty determined based on the assessment of the severity of the violations (point 2 above). In the opinion of the President of UODO, the appropriate increase in light of the impact of these circumstances on the assessment of the violations is to raise it to the amount of 2,600,000 EUR.

5. The President of UODO stated that the amount of the administrative monetary penalty determined in the manner presented above does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the penalty provided for the most serious violation (see Chapter 6 of Guidelines 04/2022). In the case of both violations identified in this matter of the provisions of Regulation 2016/679, the legally defined maximum amount of the penalty (dynamic) is the same – it amounts, as indicated above in point 2, to 59,844,162 EUR, which is 2% of the Bank's turnover achieved in 2022. Both violations thus have the same severity, and the indicated amount of the penalty of 2,600,000 EUR clearly does not exceed the maximum penalty provided for each of them

individually.

6. Despite the fact that the amount of the penalty determined according to the above principles does not exceed the legally defined maximum, the President of UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for penalty imposition (see Chapter 7 of Guidelines 04/2022). Undoubtedly, a monetary penalty of 2,600,000 EUR would be an effective penalty (due to its severity, it would achieve its repressive goal, which is to punish unlawful behavior) and deterrent (effectively discouraging both the Company and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be – in the opinion of the President of UODO – a disproportionate penalty both in relation to the severity of the identified violations (which is low both in abstracto and in concreto – see points 1 and 2 above) and due to its excessive severity – in relation to this severity. The principle of proportionality requires, among other things, that the measures adopted by the administrative authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: “A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case” (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected sectoral provisions. Commentary). Therefore, taking into account the proportionality of the penalty, the President of UODO further reduced the amount of the penalty to 330,000 EUR (equivalent to 1,440,549 PLN). In his opinion, such determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which further increases in the amount of the penalty will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the penalty could occur at the expense of its effectiveness and deterrent nature, as well as a coherent understanding, application, and enforcement of Regulation 2016/679 in relation to other supervisory authorities and the EDPB, as well as the principle of equal treatment of entities in the internal market of the EU and EEA.

In this factual and legal state, the President of the Personal Data Protection Office decided as stated in the operative part.

[1] The aforementioned guidelines updated and supplemented the Guidelines of the Article 29 Working Party on reporting personal data breaches in accordance with Regulation 2016/679 (Wp250 rev.01), adopted on October 3, 2017.

[2] Guidelines of the European Data Protection Board 01/2021 on examples regarding the notification of personal data breaches adopted on December 14, 2021, version 2.0 (hereinafter "Guidelines 01/2021").

[3] <https://www.zbp.pl/getmedia/2d3304db-34e6-4929-94cc-b9390456ff7a/infodok-2023-07-09-wydanie-55-sklad-231023-gk08>

[4] Guidelines 04/2022 on calculating administrative fines under the GDPR adopted on May 24, 2023, version 2.1, hereinafter referred to as "Guidelines 04/2022" (published at: https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under_pl).

Print article

Metadata

Provider:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-03-12

Information entered by:

Wioletta Golańska

2024-03-28 09:31:35

Last modified by:

Edyta Madziar
2024-04-02 10:06:12